

SMTP

The **Simple Mail Transfer Protocol (SMTP)** is a protocol for sending emails in an IP network. It can be used between an email client and an outgoing mail server or between two SMTP servers. SMTP is often combined with the IMAP or POP3 protocols, which can fetch emails and send emails. In principle, it is a client-server-based protocol, although SMTP can be used between a client and a server and between two SMTP servers. In this case, a server effectively acts as a client.

By default, SMTP servers accept connection requests on port **25**. However, newer SMTP servers also use other ports such as TCP port **587**. This port is used to receive mail from authenticated users/servers, usually using the STARTTLS command to switch the existing plaintext connection to an encrypted connection. The authentication data is protected and no longer visible in plaintext over the network. At the beginning of the connection, authentication occurs when the client confirms its identity with a user name and password. The emails can then be transmitted. For this purpose, the client sends the server sender and recipient addresses, the email's content, and other information and parameters. After the email has been transmitted, the connection is terminated again. The email server then starts sending the email to another SMTP server.

SMTP works unencrypted without further measures and transmits all commands, data, or authentication information in plain text. To prevent unauthorized reading of data, the SMTP is used in conjunction with SSL/TLS encryption. Under certain circumstances, a server uses a port other than the standard TCP port **25** for the encrypted connection, for example, TCP port **465**.

An essential function of an SMTP server is preventing spam using authentication mechanisms that allow only authorized users to send e-mails. For this purpose, most modern SMTP servers support the protocol extension ESMTP with SMTP-Auth. After sending his e-mail, the SMTP client, also known as **Mail User Agent (MUA)**, converts it into a header and a body and uploads both to the SMTP server. This has a so-called **Mail Transfer Agent (MTA)**, the software basis for sending and receiving e-mails. The MTA checks the e-mail for size and spam and then stores it. To relieve the MTA, it is occasionally preceded by a **Mail Submission Agent (MSA)**, which checks the validity, i.e., the origin of the e-mail. This **MSA** is also called **Relay** server. These are very important later on, as the so-called **Open Relay Attack** can be carried out on many SMTP servers due to incorrect configuration. We will discuss this attack and how to identify the weak point for it a little later. The MTA then searches the DNS for the IP address of the recipient mail server.

On arrival at the destination SMTP server, the data packets are reassembled to form a complete e-mail. From there, the **Mail delivery agent (MDA)** transfers it to the recipient's mailbox.



But SMTP has two disadvantages inherent to the network protocol.

1. The first is that sending an email using SMTP does not return a usable delivery confirmation. Although the specifications of the protocol provide for this type of notification, its formatting is not specified by default, so that usually only an English-language error message, including the header of the undelivered message, is returned.
2. Users are not authenticated when a connection is established, and the sender of an email is therefore unreliable. As a result, open SMTP relays are often misused to send spam en masse. The originators use arbitrary fake sender addresses for this purpose to not be traced (mail spoofing). Today, many different security techniques are used to prevent the misuse of SMTP servers. For example, suspicious emails are rejected or moved to quarantine (spam folder). For example, responsible for this are the identification protocol **DomainKeys (DKIM)**, the **Sender Policy Framework (SPF)**.

For this purpose, an extension for SMTP has been developed called **Extended SMTP (ESMTP)**. When people talk about SMTP in general, they usually mean ESMTP. ESMTP uses TLS, which is done after the **EHL0** command by sending **STARTTLS**. This initializes the SSL-protected SMTP connection, and from this moment on, the entire connection is encrypted, and therefore more or less secure. Now **AUTH PLAIN** extension for authentication can also be used safely.

Default Configuration

Each SMTP server can be configured in many ways, as can all other services. However, there are differences because the SMTP server is only responsible for sending and forwarding emails.

Default Configuration

Default Configuration

```
dbcyp0n@htb[/htb]$ cat /etc/postfix/main.cf | grep -v "#" | sed -r "/^\s*$/d"

smtpd_banner = ESMTP Server
biff = no
append_dot_mydomain = no
readme_directory = no
compatibility_level = 2
smtp_tls_session_cache_database = btree:${data_directory}/smtp_scache
myhostname = mail1.inlanefreight.htb
alias_maps = hash:/etc/aliases
alias_database = hash:/etc/aliases
smtp_generic_maps = hash:/etc/postfix/generic
mydestination = $myhostname, localhost
masquerade_domains = $myhostname
mynetworks = 127.0.0.0/8 10.129.0.0/16
mailbox_size_limit = 0
recipient_delimiter = +
smtp_bind_address = 0.0.0.0
inet_protocols = ipv4
smtpd_helo_restrictions = reject_invalid_hostname
home_mailbox = /home/postfix
```

The sending and communication are also done by special commands that cause the SMTP server to do what the user requires.

Command	Description
AUTH PLAIN	AUTH is a service extension used to authenticate the client.
HELO	The client logs in with its computer name and thus starts the session.
MAIL FROM	The client names the email sender.
RCPT TO	The client names the email recipient.
DATA	The client initiates the transmission of the email.
RSET	The client aborts the initiated transmission but keeps the connection between client and server.
VRFY	The client checks if a mailbox is available for message transfer.
EXPN	The client also checks if a mailbox is available for messaging with this command.
NOOP	The client requests a response from the server to prevent disconnection due to time-out.
QUIT	The client terminates the session.

To interact with the SMTP server, we can use the `telnet` tool to initialize a TCP connection with the SMTP server. The actual initialization of the session is done with the command mentioned above, `HELO` or `EHLO`.

Telnet - HELO/EHLO

Telnet - HELO/EHLO

```
dbcyp0n@htb[/htb]$ telnet 10.129.14.128 25
```

```
Trying 10.129.14.128...
Connected to 10.129.14.128.
Escape character is '^]'.
220 ESMTP Server
```

```
HELO mail1.inlanefreight.htb
```

```
250 mail1.inlanefreight.htb
```

```
EHLO mail1
```

```
250-mail1.inlanefreight.htb
250-PIPELINING
250-SIZE 10240000
250-ETRN
250-ENHANCEDSTATUSCODES
250-8BITMIME
250-DSN
250-SMTPUTF8
250 CHUNKING
```

The command **VRFY** can be used to enumerate existing users on the system. However, this does not always work. Depending on how the SMTP server is configured, the SMTP server may issue **code 252** and confirm the existence of a user that does not exist on the system. A list of all SMTP response codes can be found [here](#).

Telnet - VRFY

Telnet - VRFY

```
dbcyp0n@htb[/htb]$ telnet 10.129.14.128 25
```

```
Trying 10.129.14.128...
Connected to 10.129.14.128.
Escape character is '^]'.
220 ESMTP Server
```

```
VRFY root
```

```
252 2.0.0 root
```

```
VRFY cry0l1t3
```

```
252 2.0.0 cry0l1t3
```

```
VRFY testuser
```

```
252 2.0.0 testuser
```

```
VRFY aaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
```

```
252 2.0.0 aaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
```

Therefore, one should never entirely rely on the results of automatic tools. After all, they execute pre-configured commands, but none of the functions explicitly state how the administrator configures the tested server.

Sometimes we may have to work through a web proxy. We can also make this web proxy connect to the SMTP server. The command that we would send then would look something like this: **CONNECT 10.129.14.128:25 HTTP/1.0**

All the commands we enter in the command line to send an email we know from every email client program like Thunderbird, Gmail, Outlook, and many others. We specify the **subject**, to whom the email should go, CC, BCC, and the information we want to share with others. Of course, the same works from the command line.

Send an Email

```
Send an Email

dbcyph0n@htb[/htb]$ telnet 10.129.14.128 25

Trying 10.129.14.128...
Connected to 10.129.14.128.
Escape character is '^]'.
220 ESMTP Server

EHLO inlanefreight.htb

250-mail1.inlanefreight.htb
250-PIPELINING
250-SIZE 10240000
250-ETRN
250-ENHANCEDSTATUSCODES
250-8BITMIME
250-DSN
250-SMTPUTF8
250 CHUNKING

MAIL FROM: <cry0l1t3@inlanefreight.htb>

250 2.1.0 Ok

RCPT TO: <mrb3n@inlanefreight.htb> NOTIFY=success,failure

250 2.1.5 Ok

DATA

354 End data with <CR><LF>.<CR><LF>

From: <cry0l1t3@inlanefreight.htb>
To: <mrb3n@inlanefreight.htb>
Subject: DB
Date: Tue, 28 Sept 2021 16:32:51 +0200
Hey man, I am trying to access our XY-DB but the creds don't work.
Did you make any changes there?
.

250 2.0.0 Ok: queued as 6E1CF1681AB

QUIT

221 2.0.0 Bye
Connection closed by foreign host.
```

The mail header is the carrier of a large amount of interesting information in an email. Among other things, it provides information about the sender and recipient, the time of sending and arrival, the stations the email passed on its way, the content and format of the message, and the sender and recipient.

Some of this information is mandatory, such as sender information and when the email was created. Other information is optional. However, the email header does not contain any information necessary for technical delivery. It is transmitted as part of the transmission protocol. Both sender and recipient can access the header of an email, although it is not visible at first glance. The structure of an email

header is defined by [RFC5322](#).

Dangerous Settings

To prevent the sent emails from being filtered by spam filters and not reaching the recipient, the sender can use a relay server that the recipient trusts. It is an SMTP server that is known and verified by all others. As a rule, the sender must authenticate himself to the relay server before using it.

Often, administrators have no overview of which IP ranges they have to allow. This results in a misconfiguration of the SMTP server that we will still often find in external and internal penetration tests. Therefore, they allow all IP addresses not to cause errors in the email traffic and thus not to disturb or unintentionally interrupt the communication with potential and current customers.

Open Relay Configuration

Open Relay Configuration
<pre>mynetworks = 0.0.0.0/0</pre>

With this setting, this SMTP server can send fake emails and thus initialize communication between multiple parties. Another attack possibility would be to spoof the email and read it.

Footprinting the Service

The default Nmap scripts include `smtp-commands`, which uses the `EHL0` command to list all possible commands that can be executed on the target SMTP server.

Nmap

Nmap
<pre>dbcyp0n@htb[/htb]\$ sudo nmap 10.129.14.128 -sC -sV -p25 Starting Nmap 7.80 (https://nmap.org) at 2021-09-27 17:56 CEST Nmap scan report for 10.129.14.128 Host is up (0.00025s latency). PORT STATE SERVICE VERSION 25/tcp open smtp Postfix smtpd _smtp-commands: mail1.inlanefreight.htb, PIPELINING, SIZE 10240000, VRFY, ETRN, ENHANCEDSTATUSCODES, 8BITMIME, D MAC Address: 00:00:00:00:00:00 (VMware) Service detection performed. Please report any incorrect results at https://nmap.org/submit/ . Nmap done: 1 IP address (1 host up) scanned in 14.09 seconds</pre>

However, we can also use the `smtp-open-relay` NSE script to identify the target SMTP server as an open relay using 16 different tests. If we also print out the output of the scan in detail, we will also be able to see which tests the script is running.

Nmap - Open Relay

Nmap - Open Relay

```
dbcyp0n@htb[/htb]$ sudo nmap 10.129.14.128 -p25 --script smtp-open-relay -v
```

```
Starting Nmap 7.80 ( https://nmap.org ) at 2021-09-30 02:29 CEST
```

```
NSE: Loaded 1 scripts for scanning.
```

```
NSE: Script Pre-scanning.
```

```
Initiating NSE at 02:29
```

```
Completed NSE at 02:29, 0.00s elapsed
```

```
Initiating ARP Ping Scan at 02:29
```

```
Scanning 10.129.14.128 [1 port]
```

```
Completed ARP Ping Scan at 02:29, 0.06s elapsed (1 total hosts)
```

```
Initiating Parallel DNS resolution of 1 host. at 02:29
```

```
Completed Parallel DNS resolution of 1 host. at 02:29, 0.03s elapsed
```

```
Initiating SYN Stealth Scan at 02:29
```

```
Scanning 10.129.14.128 [1 port]
```

```
Discovered open port 25/tcp on 10.129.14.128
```

```
Completed SYN Stealth Scan at 02:29, 0.06s elapsed (1 total ports)
```

```
NSE: Script scanning 10.129.14.128.
```

```
Initiating NSE at 02:29
```

```
Completed NSE at 02:29, 0.07s elapsed
```

```
Nmap scan report for 10.129.14.128
```

```
Host is up (0.00020s latency).
```

```
PORT      STATE SERVICE
```

```
25/tcp    open  smtp
```

```
| smtp-open-relay: Server is an open relay (16/16 tests)
```

```
| MAIL FROM:<> -> RCPT TO:<relaytest@nmap.scanme.org>
```

```
| MAIL FROM:<antispam@nmap.scanme.org> -> RCPT TO:<relaytest@nmap.scanme.org>
```

```
| MAIL FROM:<antispam@ESMTP> -> RCPT TO:<relaytest@nmap.scanme.org>
```

```
| MAIL FROM:<antispam@[10.129.14.128]> -> RCPT TO:<relaytest@nmap.scanme.org>
```

```
| MAIL FROM:<antispam@[10.129.14.128]> -> RCPT TO:<relaytest%nmap.scanme.org@[10.129.14.128]>
```

```
| MAIL FROM:<antispam@[10.129.14.128]> -> RCPT TO:<relaytest%nmap.scanme.org@ESMTP>
```

```
| MAIL FROM:<antispam@[10.129.14.128]> -> RCPT TO:<"relaytest@nmap.scanme.org">
```

```
| MAIL FROM:<antispam@[10.129.14.128]> -> RCPT TO:<"relaytest%nmap.scanme.org">
```

```
| MAIL FROM:<antispam@[10.129.14.128]> -> RCPT TO:<relaytest@nmap.scanme.org@[10.129.14.128]>
```

```
| MAIL FROM:<antispam@[10.129.14.128]> -> RCPT TO:<relaytest@nmap.scanme.org"@[10.129.14.128]>
```

```
| MAIL FROM:<antispam@[10.129.14.128]> -> RCPT TO:<relaytest@nmap.scanme.org@ESMTP>
```

```
| MAIL FROM:<antispam@[10.129.14.128]> -> RCPT TO:<@[10.129.14.128]:relaytest@nmap.scanme.org>
```

```
| MAIL FROM:<antispam@[10.129.14.128]> -> RCPT TO:<@ESMTP:relaytest@nmap.scanme.org>
```

```
| MAIL FROM:<antispam@[10.129.14.128]> -> RCPT TO:<nmap.scanme.org!relaytest>
```

```
| MAIL FROM:<antispam@[10.129.14.128]> -> RCPT TO:<nmap.scanme.org!relaytest@[10.129.14.128]>
```

```
|_ MAIL FROM:<antispam@[10.129.14.128]> -> RCPT TO:<nmap.scanme.org!relaytest@ESMTP>
```

```
MAC Address: 00:00:00:00:00:00 (VMware)
```

```
NSE: Script Post-scanning.
```

```
Initiating NSE at 02:29
```

```
Completed NSE at 02:29, 0.00s elapsed
```

```
Read data files from: /usr/bin/./share/nmap
```

```
Nmap done: 1 IP address (1 host up) scanned in 0.48 seconds
```

```
Raw packets sent: 2 (72B) | Rcvd: 2 (72B)
```

VPN Servers

 Warning: Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

us-academy-1

PROTOCOL

UDP 1337 ☐ TCP 443

DOWNLOAD VPN CONNECTION FILE

Start Instance

∞ / 1 spawns left

Waiting to start..

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target: [Click here to spawn the target system!](#)

 Cheat Sheet

 Download VPN Connection File

+ 1  Enumerate the SMTP service and submit the banner, including its version as the answer.

Submit your answer here...

 Submit

+ 1  Enumerate the SMTP service even further and find the username that exists on the system. Submit it as the answer.

Submit your answer here...

 Submit

 Hint

 Previous

Next 

 Cheat Sheet

 Resources

 Go to Questions

Table of Contents

Introduction

Enumeration Principles	✓
Enumeration Methodology	✓

Infrastructure Based Enumeration

Domain Information	✓
Cloud Resources	✓
Staff	✓

Host Based Enumeration

FTP	✓
SMB	✓
NFS	✓
DNS	✓
SMTP	
IMAP / POP3	
SNMP	
MySQL	
MSSQL	
Oracle TNS	
IPMI	

Remote Management Protocols

Linux Remote Management Protocols	
Windows Remote Management Protocols	

Skills Assessment

Footprinting Lab - Easy	
Footprinting Lab - Medium	
Footprinting Lab - Hard	

My Workstation

OFFLINE

 Start Instance

∞ / 1 spawns left